# PRACTICAL LABORATORY ASSIGNMENT

| | |
|---|---|
| Full Name | OSAWARU PRAISE |
| Registration Number | C11/26/CGRCE/17564 |
| Date Submitted | 5th November 2026 |
| Course | GRC 103 Week 3 |
| Tools Used | Kali Linux, Gophish, and Mailtrap |

1. Screenshot of the GoPhish Campaign Results Dashboard.

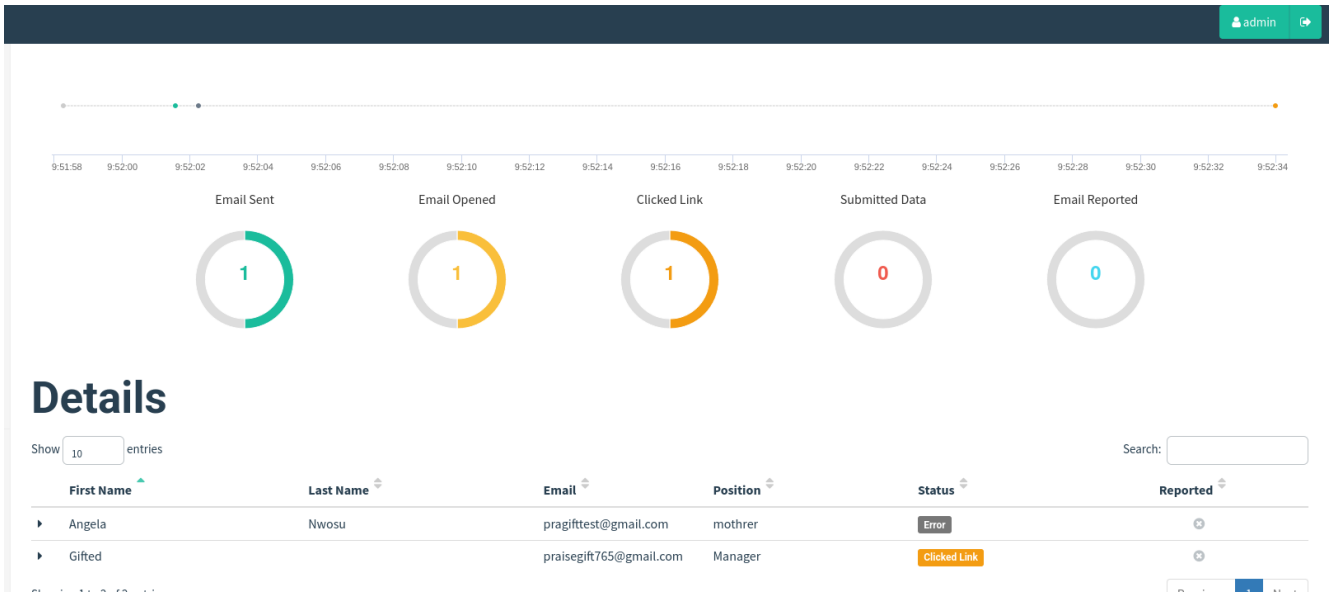



Figure 1 GoPhish campaign results

## 2. Phishing Risk Assessment Table

| Metric | Result | Calculated Rate | Risk Interpretation | Control Failure |
|---|---|---|---|---|
| Emails Opened | 1/2 | 50% | Moderate engagement with the themed email, half the test group opened it, indicating the subject line/sender alias was plausible enough to prompt at least some curiosity. | Email filtering/spam detection did not flag or block the message as suspicious.. |

| | | | | |
|---|---|---|---|---|
| Links Clicked | 1/2 | 50% | Moderate risk the one user who opened the email also clicked the link, suggesting that once opened, the email's urgency framing ("24 hours," "password expires") was convincing enough to drive action. | Users are not consistently verifying links before clicking (e.g., hovering to check the destination domain). |
| Credentials Submitted | 0/2 | 0% | Low immediate risk in this instance, no credentials were captured, meaning the user who clicked did not proceed to enter data on the landing page. | N/A in this run, but this should not be read as "no risk" |

# 3. Executive Summary and Recommendations

**To:** CISO, Head of HR, and Executive Management
**From:** GRC Audit Team
**Date:** November 5, 2026
**Subject:** Results of Q3 Controlled Phishing Simulation and Human Risk Assessment

**1. Executive Summary**

A controlled, internal phishing simulation was conducted to assess organizational resilience to social engineering attacks, using a cloned VPN password-reset scenario as the test lure. Of the test group, 50% of recipients opened the email and 50% proceeded to click the embedded link, while 0% submitted credentials on the simulated landing page. While the test group size (n=2) is too small to produce statistically reliable organization-wide rates, the results confirm that the attack mechanism, a plausible, urgency-framed email is sufficient to drive user engagement and click-through behavior. This warrants a larger-scale simulation to establish reliable baseline metrics, alongside immediate reinforcement of technical controls.

**2. Key Findings & Metrics**

- **Email Open Rate:** 50% (1/2)  indicates the sender alias and subject line were plausible enough to prompt engagement.
- **Link Click-Through Rate:** 50% (1/2) of those who opened the email, 100% went on to click the link, suggesting the urgency framing ("password expires in 24 hours") was effective at prompting action once the email was read.
- **Credential Submission Rate:** 0% (0/2)  no credentials were captured in this run. This should be read as a result specific to this small sample, not as evidence that credential-harvesting risk is low organization-wide.

**3. Risk Analysis**

This data, while limited in sample size, demonstrates that the phishing mechanism itself is viable: a convincing pretext successfully moved a user from “received” to “clicked” without any hesitation observed at the open or click stage. A successful real-world attack using this same technique could lead to:

- Initial network access for attackers via credential harvesting on a larger, more representative population
- Data breaches and financial loss
- Reputational damage and regulatory exposure (GDPR, CCPA, and similar frameworks)

The absence of credential submission in this test should not be interpreted as low organizational risk  with only two data points, a single additional click-through could shift the submission rate from 0% to 50%. A full-scale simulation (recommended minimum n=20, per industry sampling norms) is needed before this metric can inform budget or policy decisions with confidence.

**4. Recommended Actions**

- **Immediate Technical Control:** Accelerate rollout of Multi-Factor Authentication (MFA) across all critical systems, this remains the single most effective control against credential compromise, regardless of click-through rates, since it limits the blast radius even when credentials are captured.
- **Scale the Simulation:** Re-run this exercise against a statistically meaningful sample (a full department or a randomized cross-section of staff) to establish a reliable baseline before drawing organization-wide conclusions.
- **Revamp Training Program:** Transition from annual compliance videos to continuous, scenario-based training that specifically targets urgency-based pretexts (password resets, access expiration), the lure type shown here to be effective.
- **Process Integration:** Integrate phishing simulations into onboarding and run them quarterly for all staff, scaling sample size over time.
- **Policy Update:** Review and update the Acceptable Use Policy (AUP) to explicitly define user responsibilities for identifying and reporting phishing attempts.